

Security in data networks

S Forrester, M Palmer, D McGlaughlin and M Robinson

The explosive growth of data networks and their commercial application is driving the need for improved security. This paper aims to raise awareness of the features of secure data networks and the role that encryption plays in this context. An overview of data network security is provided by examining a number of currently available technologies, and how they may be combined to provide a secure network. This is illustrated by a review of existing and proposed encryption services offered by BT/Concert. Taking a glimpse into the future, the ATM Forum's proposals for security in ATM networks are summarised.

1. Introduction

The growth of data networking in both corporate and domestic environments is bringing more attention to the vulnerabilities which exist in open data networks. As we move into the 21st century, effective and efficient security will gain more prominence as a key service, offering new business opportunities to BT. This paper aims to show how BT is rising to meet the challenge, and what form the future of security in data networks may take. Although it concentrates on the corporate data world, issues affecting domestic users are also considered.

This paper discusses general security issues and, more specifically, security afforded by encryption systems in data networks. This is illustrated by an overview of security services that are currently offered by BT and Concert or are about to be launched. A brief guide to the security services offered is provided along with a description of the types of encryption solution available.

Basic security principles, some relying on the mathematics of cryptography, combine to provide services such as access control and confidentiality. These are applied to network elements to provide managed security solutions, protecting data and devices from attack by unauthorised individuals or other devices, while allowing legitimate user access in line with a company's security policy (see Fig 1).

This paper is concerned with how managed security solutions are provided from basic security service types and applied in networks. How a company's security policy is implemented is beyond the scope of the paper.

1.1 Motivation

The key drivers for BT's investigation and development of encryption in data networks are listed below.

- Growth in data communications

Computer internetworking is growing at an unprecedented rate, and is forecast by many to grow even faster. Ever greater numbers of organisations are implementing and expanding corporate networks using new access devices and Internet-related technologies; the number of individual users connected to the Internet follows the explosive growth trend. This is resulting in increasing volumes of sensitive information in transit either across the Internet, or within intranets connected to it. The consequence is high demand for new products to satisfy data transmission security requirements.

- Cost benefit

The cost to a business of breaches in security can be high. However, the benefit of expenditure on security needs to be weighed against the real risk, which is dependent not just on the value of the assets to be protected and the level of vulnerability, but also on the extent of the threat. For example, is the cost of breaching the security system (e.g. encryption algorithm) greater than the value of the assets (e.g. data) that can be stolen? While this assessment is fairly simple in the case of the financial institutions (it is merely the value of the transaction authorised), it is more complex for corporations whose data is harder to quantify in financial terms.

- Increasing demand for BT's data services

The cost-effectiveness of switched WAN services (e.g. Frame Relay, switched multimegabit data services (SMDS) and CellStream as replacements for leased

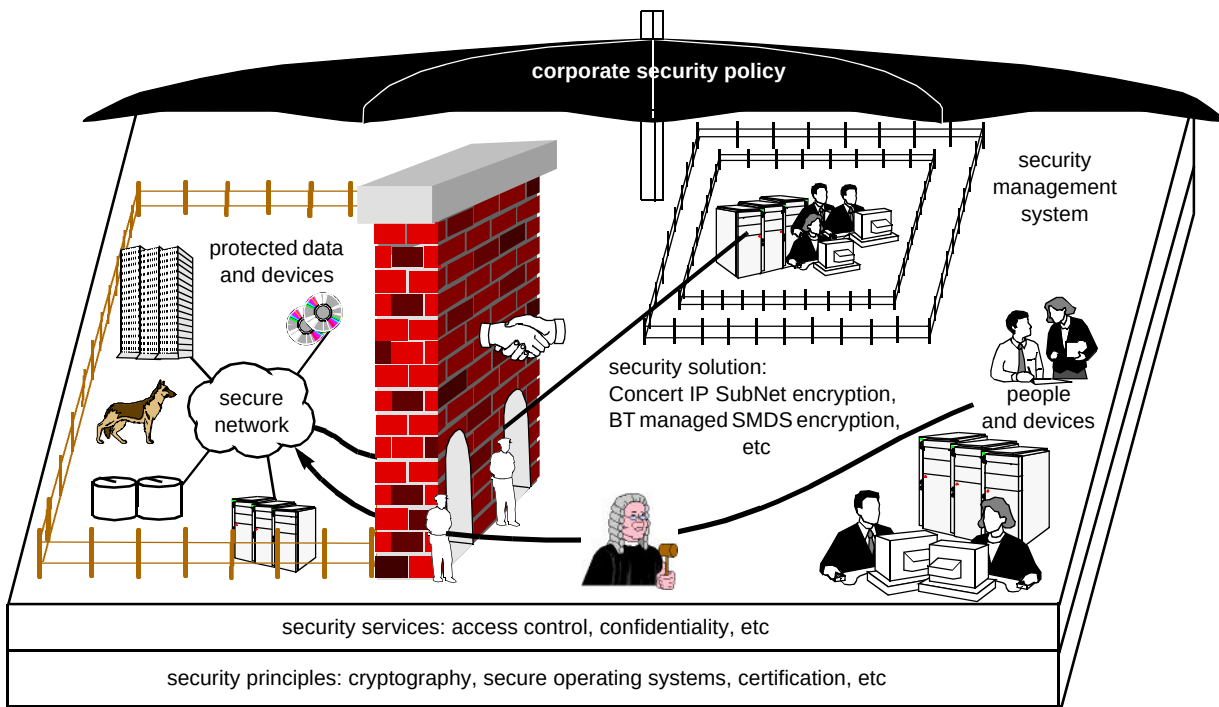


Fig 1 Context of managed security services.

lines) is driving the need for security developments at the packet switching layer, as a replacement for bulk line-cryptography.

- Customer demand for fully managed services

Customers are changing their business practices by concentrating more on their core business. BT is acting more as an out-source agency, providing fully managed data networks on behalf of its customers, with a corresponding need to provide security services in order to protect customers' data.

- Legal requirements on behalf of the user

The law affecting security is unclear in many areas. However, BT must abide by the Data Protection Act, and, for example, networks used by banks must not compromise the demands of the Banking Act. Some responsibility could potentially devolve upon network providers in cases of illegal or immoral use, copyright protection, data theft and fraud.

1.2 International aspects

Much company trading is across national boundaries and between different network providers. It is therefore desirable that encryption systems be available to work across international networks. To this end a number of proposals are currently under national and international debate to satisfy the various objectives. Among these are the issues of key escrow and trusted third parties. These proposals have been discussed at some length elsewhere (see Phoenix [1]) and will not be considered further in this

paper, except to state that they will have some bearing on the future services that can be offered. These are unlikely to have a bearing on our existing and emerging encryption services.

2. Security services

Encryption is often regarded as a universal panacea for security, leading many to believe that it is the complete security solution. However, data encryption alone merely offers data confidentiality or privacy.

To provide a complete security solution a number of security services need to be offered. The most important of these are:

- access control,
- confidentiality or privacy,
- data integrity,
- authentication and replay prevention,
- scalable key management,
- auditability and accountability.

In many vendors' encryption solutions a number of these additional services are catered for, but it should always be borne in mind that not all solutions will provide all of these services. Some vendors merely provide 'hooks' for users to implement their own solutions, or ensure that their products are compatible with other vendors' products

or industry standards. The strength of individual solutions depends critically upon the quality of implementation.

2.1 Access control

Controlling access to data and resources is a key element of security management. Techniques include:

- password access to a file server and user/group read/write/execute permissions to files, thereby controlling access using the host's operating system (see Fig 2),
- similar password access to restrict who can configure network devices or dial into a network — access control servers provide centralised management and logging for these functions, plus additional features (e.g. authentication, see section 2.4) to improve security,
- at the network level, most routers have the ability to provide a degree of security by barring traffic on the basis of addresses, protocols, etc, using access control lists. Newer, stand-alone 'firewalls' are increasingly being used to deny attacks by employing techniques that detect and trap prohibited packets at a network gateway. Hubbard and Sager provide an intensive treatment of firewalling techniques [2].

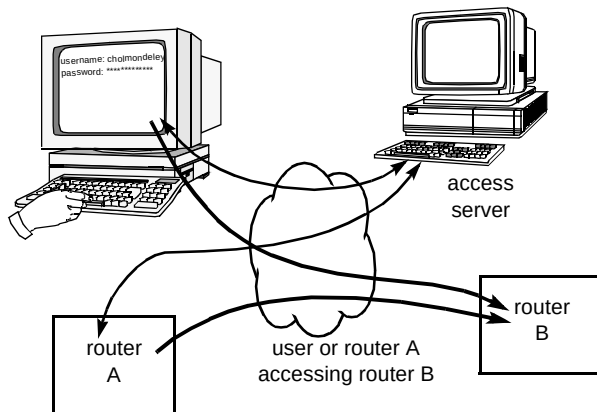


Fig 2 Access control.

2.2 Confidentiality or privacy

Ensuring privacy or confidentiality of data (Fig 3) is the primary service offered by an encryption system. The extent to which this is achievable depends on the strength of the encryption algorithm used. A fundamental assumption used in the design of encryption algorithms, is that any attacker has complete knowledge of the algorithm and implementation. This is known as Kerckhoffs' assumption [3], and it suggests that the cryptographic strength of the encryption system is invested entirely in the keys with which information is cryptographically locked and unlocked. Thus, the longer the key, the more secure the encryption system.

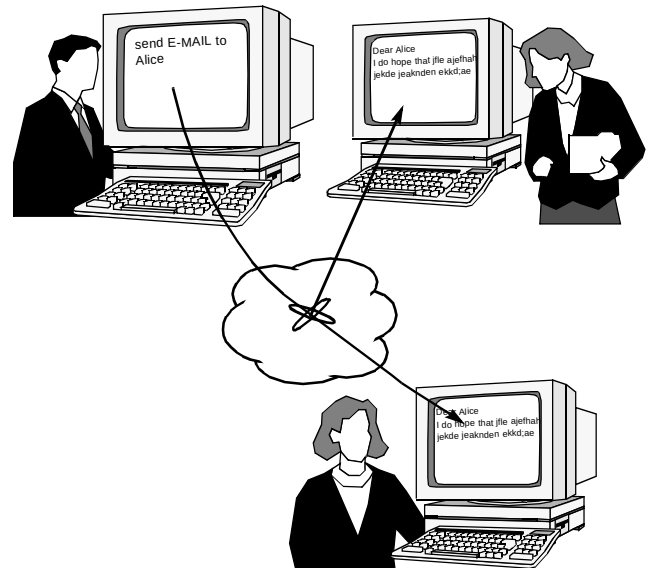


Fig 3 Invasion of privacy.

The strength of an encryption algorithm, by virtue of the key length, is well recognised. For example, the US government currently allows export of encryption systems with effective key lengths of up to 40 bits (weak encryption). For key lengths of 56 bits and above (strong encryption), export controls exist to prevent the proliferation of strong encryption systems (see section 1.2). It is worthwhile pointing out that the prizes for RSA's 40-bit and 56-bit challenges have been claimed. Following the cracking of a 40-bit RC5 cipher in three and a half hours in January 1997 [4], a 56-bit DES cipher was cracked ¹ over a four-month period to June 1997 [5]. In both cases, less than 35% of the key space was searched using an array of Internet volunteers and computing resources from industry, universities, and government. Assembling the resources necessary to crack a static challenge is somewhat easier than attacking a live system. Nevertheless the days of referring to 56-bit ciphers as strong encryption are clearly numbered. In response to this, vendors are increasingly providing algorithms with longer key lengths (e.g. triple-DES which has an effective key length of 112 bits).

A detailed description of encryption algorithms and associated design issues is beyond the scope of this paper and has been dealt with in Phoenix [1].

2.3 Data integrity

The purpose of providing an integrity service is to prevent data packets (i.e. the content itself, or the headers that control their route, security level, etc) from being modified in transit (Fig 4). Integrity checking also prevents, or, more accurately, detects, the insertion of illegitimate information.

¹ It should be emphasised that the keyspace of a 56-bit key is about 65 000 times longer than that of a 40-bit key, implying a corresponding increase in the expected 'cracking' time. The fact that this was not born out in practice reflects the differences in the amount of keyspace that was searched in arriving at the correct key.

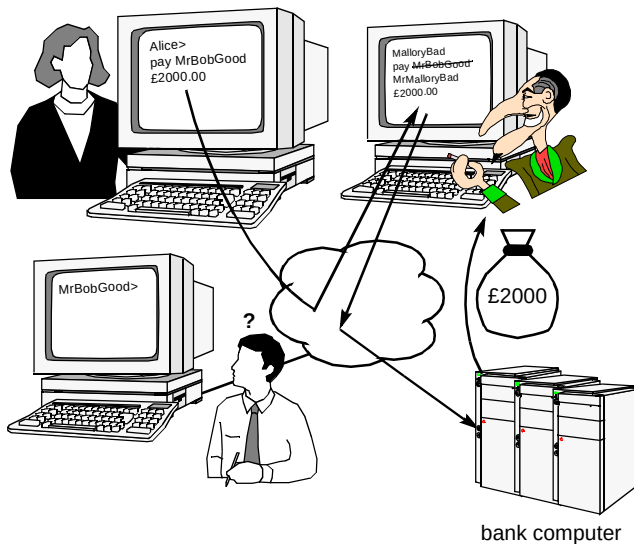


Fig 4 Loss of data integrity.

Integrity services are typically provided by including a signed digest or hash of the data with the message. A hash function may be considered to be similar to a CRC function in that, for any variable-length message, a fixed-length string (called the hash value) is returned. Unlike a CRC however, it is very difficult (unfeasible) to modify a message such that the hash function returns the same value as the unmodified message. The key requirements of the hash function are as follows:

- the input message can be any length,
- the output (hash value) has a fixed length,
- it is easy and fast to compute the hash value,
- it is a one-way function, i.e. it is not possible to compute the original message from the hash value,
- it is 'collision free', i.e. it is hard to generate two messages with the same hash value.

MD5, SHA and DES-MAC are examples of well-known hash functions. MD5 is used for routing authentication (see section 4.2).

To ensure the integrity of a message, the hash value is cryptographically signed. This is achieved by using an appropriate digital signature technique, generally based on public-key cryptography, e.g. the digital signature algorithm (DSA). The integrity of the message now depends on the integrity of the digital signature and is therefore inextricably linked with authentication (i.e. the authenticity of the signature). It is worthwhile pointing out that the integrity of a message does not rely on the message itself being encrypted — merely the hash of the message via the digital signature. The use of encryption for this purpose is not constrained by export controls and thus integrity checking schemes can be deployed without special licences.

Furthermore, as it is the hash of the message and not the message itself that is effectively encrypted in this way, the performance of integrity services, particularly in software implementations, is superior to the performance of privacy services.

Some encryption product vendors provide message integrity services, but few allow the option of integrity checking without encryption.

An integrity service that ties a user to a particular data flow (source, destination, time, etc) can also be used as the basis of accountability and audit services. Such a mechanism can be used as a basis for non-repudiation and could, in the future, provide legal proof of origin; at the time of writing the legal status of such services has not been defined in law.

Although per-packet signing prevents packets being inserted into a message, it does not prevent packet loss or re-ordering, for which other techniques must be employed, e.g. replay prevention.

2.4 Authentication and replay prevention

Authentication is a service that verifies the identity of a person, host, device, a piece of code or data. In its most general sense it is the means by which evidence of identity can be passed across a network. Weak authentication schemes forward identity-related information in the clear; strong authentication schemes make use of encryption - the strongest schemes use multiple, encrypted challenge-response protocols.

Authentication can be used to ensure data integrity, as noted above, and to verify that data is sent and received by legitimate end-points. It may also be used as a mechanism by which users can prove their identities to one another or to services to which they are seeking access (e.g. a user ID and password are typically used to authenticate access to a workstation). An example of one-way authentication is where a dial-in network needs to authenticate user access, but the users do not authenticate the network.

In a secure networking environment, the purpose of authentication verifies the encryption devices that make up the secure network. Many authentication systems employ digital signatures together with public-key cryptography and challenge-response protocols. A frequently used authentication mechanism is based on the RSA public-key cryptosystem [6].

Replay prevention is a service that prevents an eavesdropper from capturing data and subsequently replaying it for nefarious purposes (Fig 5). Perhaps the clearest example of this would be a hacker capturing the data from a cash-card transaction at a Automatic Teller

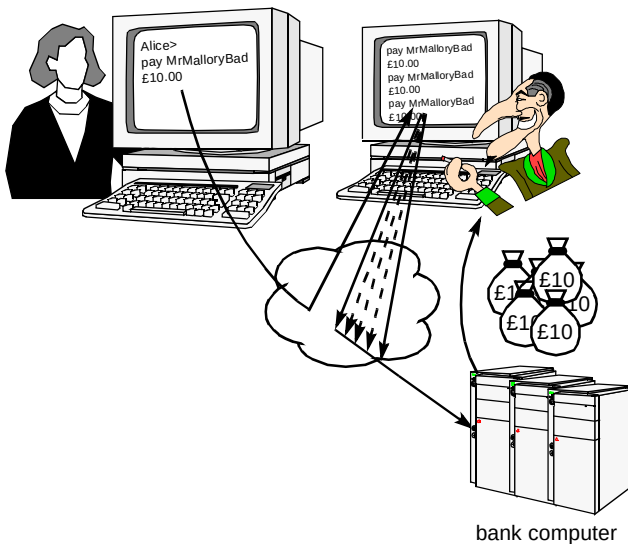


Fig 5 Data replay.

Machine and replaying it in order to extract cash from the machine. Replay prevention can be avoided using large sequence numbers or digital time stamps. In both cases the end-user systems must be capable of synchronising the sequence numbers or time stamps so that each transaction is unique.

An authentication service, along with replay prevention and other measures, ensure that data integrity is preserved.

2.5 Scalable key management

Key management, or the generation and secure distribution of cryptographic keys, is the most difficult problem to solve in the provision of an encryption based security system (Fig 6). It is vital that the keys generated are random and that they can be distributed to the end systems that need to use them without being compromised. Furthermore, if the secure network contains a large number of end nodes, the key management system must be scalable.

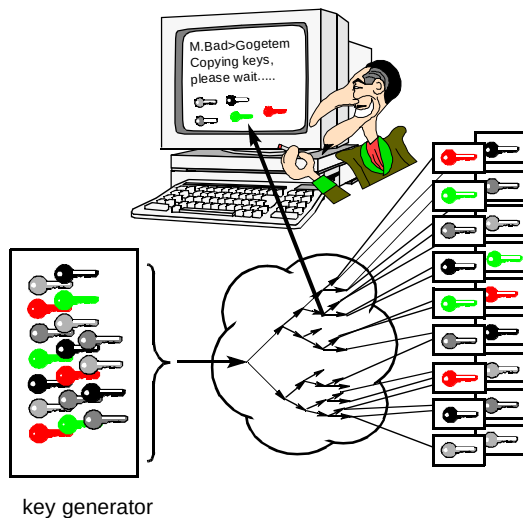


Fig 6 Compromise of key distribution.

The scalability of the key management is a major consideration in the security of large corporate enterprise networks. Key distribution must also be timely to ensure that keys are available when they are needed. Some method of cancelling keys (key revocation), or forcing updates, is also essential.

As hinted at above, key distribution in symmetric or private-key encryption systems has been a management problem for quite some time, as the security of the system is predicated on the reliable and secure distribution of the keys. Traditionally, this involved the physical transportation of the key in a tamper-proof enclosure and was often achieved using motor-cycle couriers — some systems using bulk line-encryption still use this method. The invention of public-key encryption systems has greatly simplified the key distribution problem; the two most popular public-key distribution methods are Diffie-Hellman [7] and RSA [6].

Public key cryptography is predicated on the principle that it is very difficult to factor large numbers. Since there is no way of proving that factoring large numbers is difficult and that no new methods will be, or have been, discovered for accomplishing this, some authorities (e.g. the military) will not trust public-key encryption. Managing systems that do not use public-key cryptography is a complex and labour-intensive problem.

Diffie-Hellman

The Diffie-Hellman key agreement protocol is a form of public key encryption system that allows two parties to exchange information (i.e. two large numbers) in the clear, from which a third number can be deduced. The third number can then be used as a session key to encrypt data that passes between the two parties (e.g. encryption units). It is unfeasible for any third party, even with access to both of the numbers passed across the network, to deduce the third number. The strength of the Diffie-Hellman protocol is that it enables a secret key to be agreed between two parties without ever having to pass the key across the network. A further advantage in this approach is that the secret key is based on numbers generated by the parties at each end of the link. This means that the session key deduced from these numbers is based on two random number generators. Thus if one random number generator (i.e. at one of the encryption units) is underperforming, the randomness of the session key is assured by the other.

This technique (Fig 7) is vulnerable to a 'piggy-in-the-middle' attack, in which the attacker intercepts messages from two communicating parties, and masquerades to each party as if he were the other.

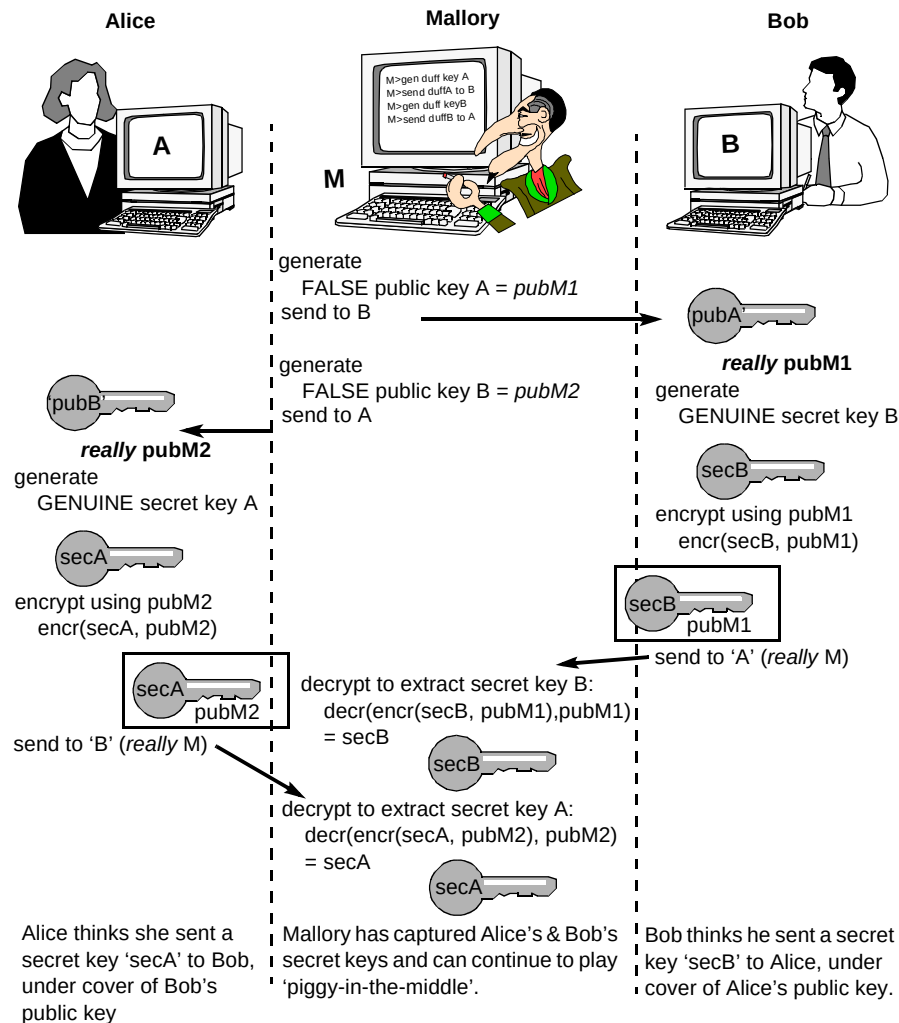


Fig 7 'Piggy-in-the-middle' attack.

Rivest, Shamir and Adleman (RSA)

The RSA public-key encryption system can be used to securely distribute secret keys by encrypting them in what is sometimes referred to as an RSA envelope. RSA is similar to Diffie-Hellman in that it uses the idea of a key-pair to provide the encryption system. The key pairs consist of a public and a private key. Data may be encrypted using either the public or private key while the decryption process uses, respectively, the private or public key. The public keys are known to all who may wish to use the system but the private keys are known only to the owner. The strength of this system is predicated on the unfeasibility of deducing the private key from the public key and vice versa. As with Diffie-Hellman this system can be subject to a 'piggy-in-the-middle' attack and thus it is essential that the authenticity of the published public key is assured.

The need for trust

The creation of keys used purely within a private domain may be performed by a cryptographic unit,

transparently to the user. In the case of generation and storage of public keys, the problem of trusting a source is greatly more significant — a system is required which will manage relationships of trust, and reliably issue and deliver digital certificates to users of the keys (see next section). In the case of a corporate network the 'public' keys reside within a closed system, typically the management system. In a truly public service (e.g. individuals conducting commerce over the Internet) the public key is issued by an independent agency and thus the issue of trust is more significant and subject to legislation [8].

Certificates

As noted above, public-key encryption systems rely on the authenticity of the published public key. Certifying that such a key is genuine is part of the authentication process. A certificate is what attests to the validity of a key, and is presented to the user along with the key. The certificate is created so that the user knows that it, and hence the key also, has been sourced from the genuine party.

In the context of a public key, a certificate is a piece of information (i.e. digital document) attesting to the binding of a public key to a specific individual or an entity (e.g. encryption unit). Certificates allow the claims of legitimacy of the public key to be verified and thus help prevent an individual or entity claiming to be someone or something that they are not. They may be considered to be similar to an identity card or passport.

Typically the information contained within a certificate will contain the individual (or company) name, the public key, a version and serial number for the certificate, the certifying authority, the certificate expiry date, the identity, and, very importantly, the digital signature of the certifying authority. ITU Recommendation X.509 [9] specifies a certificate syntax or format that has been widely adopted in security circles. In a secure network a number of certificates will typically be required to attest to the authenticity of public keys used by network elements. The security management system will typically reside at the top of the certificate hierarchy and thus be the certifying authority responsible for the generation of the certificates.

2.6 Auditability and accountability

To support the traceability of the management system a security audit log is generally used (see Fig 8). This should record changes to the secure network as well as any changes in the security parameters (e.g. key lifetimes, certificate expiry, etc). The more detailed the audit log, the better the traceability of the system and hence the more likely the system is to meet the needs of a corporate enterprise.

3. Types of encryption solution

Encryption solutions fall into three broad categories depending on where they operate in the communications stack (see Fig 9).

3.1 Application and host layer encryption

Encryption at the application layer allows for the highest level of security in that the encryption process is as close to the source (and decryption to the destination) of the protected data (e.g. the end users) as it can be. Thus complete end-to-end security can be provided on a user-by-user basis. This relies on all users having access to the appropriate encryption applications at client workstations and serving hosts. However, not all applications support encryption, particularly those that assume the use of link-layer encryption solutions. With application-layer encryption it is the responsibility of individual users (or host managers) to comply with the corporate security policy. As such it is not completely reliable from a security administrator's perspective (i.e. complete coverage cannot be assured).

Examples of application-layer encryption include, but are not limited to, the following:

- Secure/Multipurpose Internet Mail Extensions (S/MIME),
- Secure HyperText Transfer Protocol (S-HTTP),
- Message Security Protocol (MSP),
- Pretty Good Privacy (PGP).

Other examples of application-layer encryption include those used in the banking industry for secure electronic transactions (SET) which relate to purchases over a public network using a bank card.

Host layer encryption is provided by programmes which are accessible to several or (ideally) all applications, performing encryption/decryption on behalf of the application. Examples of currently available host-level encryption software include Netscape's SSL (secure sockets layer), also supported by Microsoft, along with PCT

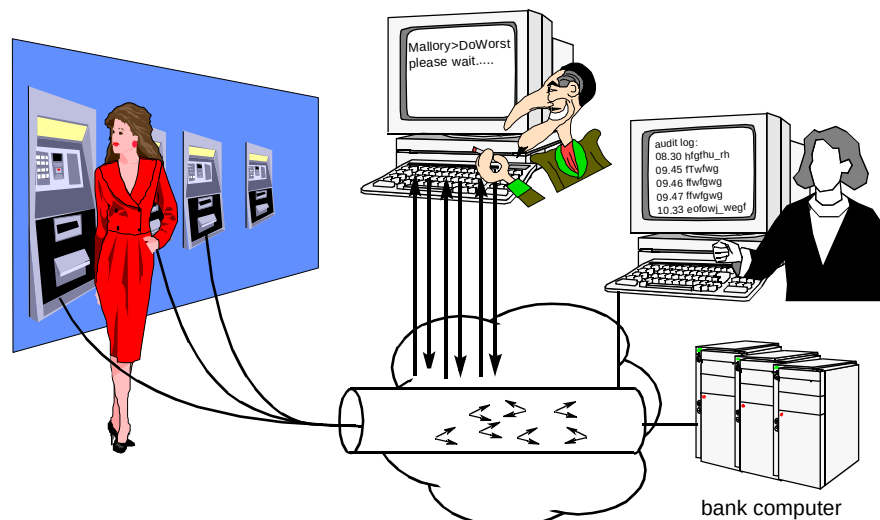


Fig 8 Inspection of audit log.

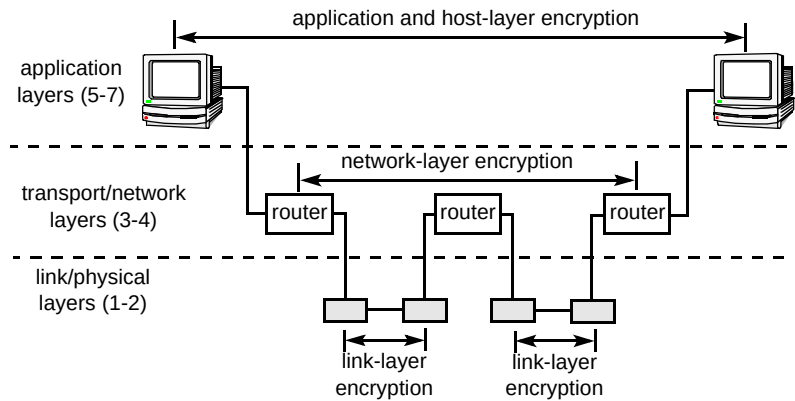


Fig 9 Location of encryption solution in the communications stack.

(private communications technology). Earlier versions of applications may not be compatible with these packages.

SSL is inserted at a sub-layer between the standard WinSock module and the base TCP/IP provider (Fig 10). Future developments of such modules may well be influenced by legislative requirements, for example, providing key escrow (see section 1.2) [1].

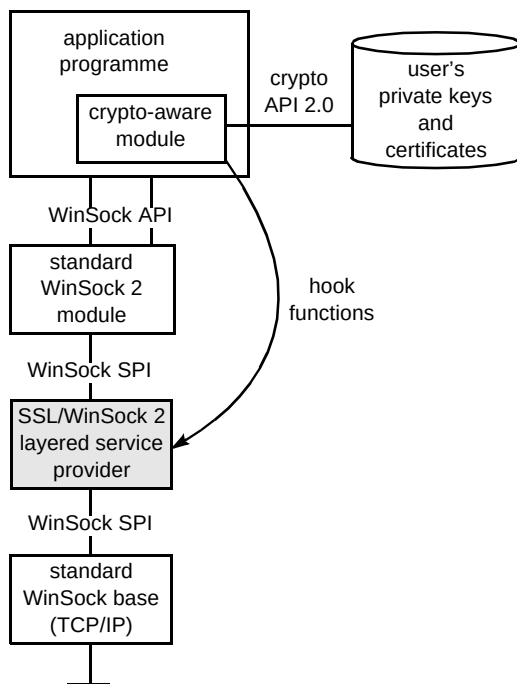


Fig 10 Using the SSL dynamic link library.

3.2 Network layer encryption

Moving the encryption function from the application layer to the network layer removes the dependency on end applications and shifts the responsibility from the end users to the administrators of the networking devices, e.g. routers. Encryption at the network layer has the advantage of operating transparently both between subnetwork boundaries and from the end user's perspective. Consequently the network administrator is well placed to

reliably enforce the corporate security policy. Network encryption encrypts traffic on a connection basis between specific source and destination nodes (e.g. IP addresses) or subnetworks (e.g. IPX network addresses). This allows both flexibility in the implementation of security policies within an organisation, and enables departments to be logically and securely separated via the network encryption device.

For network layer encryption to work, it must be transparent to intermediate network-layer devices and thus it encrypts only payload information — the network-layer headers must remain in the clear. For some organisations (e.g. military, government, etc), the fact that source and destination addresses pass across the network as plain text (i.e. 'in the clear') is a security risk. This is simply because an eavesdropper may be able to deduce useful information about the organisation based on traffic profiles. For this type of organisation, encryption at the link layer may be a more appropriate solution.

Network-layer encryption is, by definition, network protocol specific. The network-layer encryption device may not be capable, as such, of supporting all the network protocols used by the corporation¹. Furthermore, any breaches of security at the network level may compromise many users without their knowledge. The chief advantage of using network-layer encryption is that it is, in general, media and interface independent which can make it topology independent. At the time of writing most network-layer encryption devices are software-based and as such are quite slow. Some vendors have, in recognition of the poor performance of software-based encryption, produced hardware-based solutions.

The IP Security Protocol Working Group (IPSEC) of the Internet Engineering Task Force (IETF) — the body that defined the Internet protocol — is developing security mechanisms to protect client IPs. These developments have resulted in the publication of a number of request for comment (RFC) documents and draft standards. RFCs that are more mature (e.g. IP Version 4 and the proposed IP

¹ It is worth noting that if IP is supported, the majority of corporate network protocols can be supported by encapsulation in IP. SNA is often carried over IP-based networks in this way

Version 6) are undergoing trials. The main two IPSEC security protocols, AH (authentication header) and ESP (encapsulating security payload), will have protocol formats that are independent of the cryptographic algorithm employed. The initial goals will target host-to-host security with subsequent aims to deal with subnetwork-to-subnetwork and host-to-subnetwork topologies. Techniques will also be developed to support the key management requirements of the network-layer security. The Internet security association and key management protocol (SAIKMP) will be specified as an application-layer protocol, independent of the lower layer security protocol. At the time of writing, AH and ESP are near to standardisation, and the new architecture draft should soon be completed. Some additional work is required, with more than 20 IPSEC-related Internet drafts being under review.

3.3 *Link-layer encryption*

Encryption at the link layer is the most common approach and link-layer encryption devices have been available for some time in the form of bulk line-encryptors for various link layers including KiloStream and MegaStream2. Link-layer encryption encrypts all traffic on a given link, except the link-layer headers, i.e. network-layer headers and protocol-type information which enables it to be protocol independent. Typically (e.g. for bulk line-encryptors) each encrypted link has separate keys, but all traffic on a given link is encrypted under the same key. The disadvantages of this approach are that the encryption device is specific for a given medium or interface type and that encryption has to be performed on a link-by-link basis. In a large network a number of different link layers may be used to provide the required connectivity. Thus, in traversing the network the traffic may need to be independently encrypted and decrypted several times by different devices each of which may use different management techniques. Thus link-layer encryption is extremely dependent on network topology.

A newer class of encryption device has emerged in the last two to three years. These are used in public switched networks that route data at the link layer (layer 2), such as Frame Relay or SMDS. These arguably fall between the network layer and link layer descriptions given above, on the basis that they are specific to the interface type as well as dependent on the link-layer protocol. These devices have the flexibility to encrypt selectively on the basis of the layer 2 addresses, i.e. source and destination pairs. Thus, unlike traditional link-layer devices, the traffic is encrypted on a connection-by-connection basis with a different key used for each connection.

These devices still act as link-layer devices, i.e. they are dependent on network topology and can only offer end-to-end encryption if the same networking technology is used throughout the network. If, for example, it is necessary to route or switch traffic at layer 3 at some intermediate point

in the network (e.g. IP routing), the traffic will need to be decrypted at this intermediate point in order to restore the layer 3 routing information. To complete its journey through the network securely, the traffic will need to be re-encrypted. Thus several encryption devices and several keys may be required to provide end-to-end encryption.

This intermediate decryption means that such an intermediate point could be a primary target for an attack. In practice, the intermediate point would generally be located within the customer's premises along with the access equipment, and thus be afforded the same security protection as that access equipment. Any circumstances in which this is not the case will need careful consideration.

Most link-layer encryption devices are hardware based to provide a high performance in terms of both speed and latency to satisfy the requirements of the link-layer interface.

4. **Securing standard network components**

Most secure networks will contain a variety of standard network equipment in addition to encryption devices. If they are used to join encryption devices together, then it is especially important to make them secure too. Although encryption should hide the data from an eavesdropper, it is necessary to prevent the network between the encryption devices being disabled, or data cannot be carried.

4.1 *Routers and bridges*

Networks of any size will contain some form of switching nodes. Bridges forward packets based on their layer 2 (e.g. Ethernet MAC) destination address, while routers forward packets based on their layer 3 (e.g. IP) destination address. Both these types of device build tables containing a mapping between destination address and output port.

Bridges build these tables by monitoring traffic flows. If the bridge does not have the mapping for a destination it will send the packet out of all ports (except the one it arrived on). In this way the packet will eventually reach its destination (assuming the destination exists). The bridge also looks at the source address of every packet it sees. These are used to build the bridge table, mapping the address of a device to a port. Hence anyone who can generate packets with a chosen source address (the same as the address of a genuine device) can corrupt the bridge tables. Typically this would lead to traffic for the genuine device being sent to the attacker instead. This type of attack means that bridges should not normally be considered secure. Modern 'LAN switches' also function in the same manner as bridges. Hence the use of either of these devices in secure networks needs careful consideration.

Routers can have their routing tables manually configured. However, this process becomes impractical in larger networks, and does not adapt automatically to changes in the network (such as the failure of a link). Hence most routers build their routing tables by running a routing protocol. This involves the routers throughout the network telling one another about which destinations are available. Hence the routing table of a specific router is based on information from many other routers. Thus there is a danger that an attacker could create routing protocol packets to manipulate the routing tables of one or more routers. This becomes an important issue when routing information is passed in the clear — this is discussed in the following section.

4.2 *Routing authentication*

Among routing protocols that have built-in authentication capability are OSPF and Cisco's EIGRP. Some of the issues associated with such protocols are discussed with reference to OSPF, a protocol commonly used for larger data networks [10]. Initial definitions of OSPF [11] optionally allowed packets to be authenticated with a 'plain-text' password. In this scheme, all routers directly connected to the same network are configured with the same password, inserted (unmodified) into every OSPF packet. When OSPF packets are received from this network, the password field in the packet is checked against the locally configured password. If they match, the packet is processed normally, potentially making a change to the routing table. Otherwise, the packet is ignored.

Anyone with access to part of the network will receive the OSPF packets, including the password, which can be extracted and used to forge OSPF packets with the valid password. Such forged packets could be used to modify the routing information throughout the network. Such an attack could be contrived to deny service or even steal data. Hence the 'plain-text' password scheme should not be considered a proper defence against malicious attack.

More recently, a better authentication scheme has been used for OSPF [12]. Again, all routers that are directly connected to one another are configured with the same 'secret'. The normal contents of the OSPF packet, plus this secret are run through the MD5 algorithm [13]. When a router receives such an OSPF packet, it stores the MD5 value from the input packet. The router then runs MD5 using the rest of the OSPF packet and its own value of the secret. If values match, the packet is accepted. The risk of replay attack can be minimised by including a 'cryptographic sequence number' in each packet. The sender is never allowed to decrease this value from the last packet. The receiver discards the packet if the cryptographic sequence number is smaller than that previously received from the same sender, thus limiting the time window over which a given packet can be used for a replay attack.

The scheme described above is a significant improvement over the 'plain-text' password scheme. However, routers only authenticate transactions with directly connected routers, so any single router being compromised will pass on incorrectly 'authenticated' data to the rest of the network. A new security scheme for OSPF has been produced as an experimental RFC [14], which proposes having a few trusted entities within the network to provide certification of routers' public keys. Public-key encryption is then used to provide digital signatures of all information by the source of the information. This signature stays with the information as it is propagated through the network. Routers can obtain the public key for the source from the trusted entity, and a range of networks which the source is allowed to advertise. This can be used by any router to determine that they have received a valid advertisement. Although this scheme is not currently used by commercial implementations, the results of this work may influence OSPF authentication in the future.

4.3 *Access control servers*

Access control servers were initially created to control the use of terminals and dial-in lines for access to computer resources and networks. More recently their application has extended to controlling the configuration of network devices such as routers. In such cases, the user name and password of each user could be configured on every device they use. Growth in the number of systems the user accesses makes it increasingly difficult to manage the configurations. With a very large number of users, the database may also become unwieldy. Access control servers are aimed at reducing this problem and also enabling various sophisticated techniques to be used. Once an access control server is deployed, any network device which needs to authenticate a user passes the user name and other information (e.g. password) to the access control server (Fig 11). The access control server will then send a reply stating whether the user is allowed access. Some access control protocols are discussed in more detail below.

A number of access control protocols have been developed for communication between network devices and access control servers. Popular examples include TACACS [15], TACACS+ and RADIUS [16, 17]. Each of these provides authentication of the user. Both TACACS+ and RADIUS also provide for accounting messages to be sent to the access control server for logging. Additionally TACACS+ defines authorisation messages which can be used to verify which commands or actions a user is allowed to perform. TACACS messages do not include any additional protection mechanisms and so are vulnerable to attack. TACACS+ and RADIUS require a 'secret' to be configured on the network device and server. This is then used to generate authentication of all messages between the network device and server. Additionally, both of these protocols encrypt password fields to prevent eavesdropping

(TACACS+ encrypts most other fields, too). The methods employed do not require the 'secret' to be sent across the network. Additionally, these two protocols employ methods which prevent captured packets being successfully used in a replay attack.

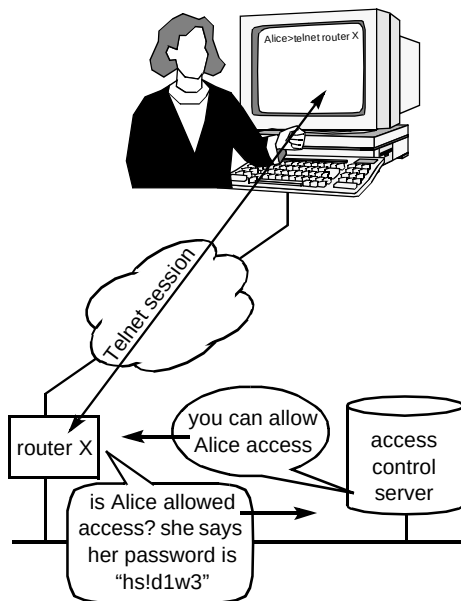


Fig 11 Use of an access control server for router access.

The use of an access control server to provide centralised authentication makes it possible to implement sophisticated techniques for user authentication. To reduce the consequences of eavesdropping, a number of 'one-time key' techniques have been developed. These systems try to ensure that the 'password' is different each time, hence information gleaned from eavesdropping should not provide the attacker with significant useful information. Two basic approaches used by commercial systems are 'random' access code and challenge-response.

In a typical 'random' access code system, each user is provided with a credit-card-sized device. This generates a 'random' number every minute by encrypting information based on the current time and the card serial number using a secret key held in the device. The information, including the secret encryption key, is also known to the access control server (and must not be known to anyone else). When users attempt to access a network device, they enter their user name and use the 'random' number generated by their card as the password. Because the access control server's time reference is synchronised with the card, the 'random' number generated by both will be identical and hence the user will be granted access.

Additional security is provided by challenge-response systems. Here the user possesses a device which appears more like a calculator. The access control server generates a 'challenge' number which is displayed to the user. The user then enters this into their device to generate the response which will depend on both the challenge and some secret

information. This response is returned to the access control server and can be compared with the expected response (since the server should be the only other device which knows the secret information). This arrangement is very similar to the CHAP protocol used for authentication of dial-in links [18]. A major requirement of such a system is that the challenge is never repeated, thus preventing a replay attack.

The use of such physical 'one-time keys' can be worthwhile in many environments. Typically a standard 'fixed' password is used in addition to the one-time key. This is beneficial as it reduces dependency on the one-time key alone.

Similar one-time keys are also available as software and several manufacturers sell software which performs identical functions to their hardware products, at lower cost. However, such software products are far more open to attacks due to the comparatively poor security of most PCs and workstations.

4.4 The weakest link?

Many other factors need to be considered to make a system secure, especially when standard network components are used. Some of these are discussed below, though these are by no means an exhaustive set.

Physical security of network components (and sites in general) is important. Physical security of computers, especially servers, should reduce the threat of wholesale data theft by removal of hard drives. Additionally many computer systems and network devices have weaker security when accessed locally.

Standard network components are often remotely managed using protocols such as Telnet and TFTP. Since these are not themselves encrypted, an eavesdropper who can tap into such sessions 'in the clear' can discover valuable configuration details such as passwords or secret keys. Additionally, it is normally necessary to add configuration options to obtain a secure system. Thus, if the configuration is set up or modified incorrectly, weakened security will result. In some networks, configurations are regularly checked to ensure that they are correct. Tools can also be used to detect weaknesses (which can then be corrected). As well as adding certain security options, configuration should be used to disable any services which are not required. This prevents these services being used maliciously and is important because many services (e.g. e-mail) can contain bugs that are exploitable. Also, many network components generate audit trails and logs (e.g. failed authentication attempts), and this information can be examined regularly to detect attempts to break into or misuse the network.

Passwords can be made more secure by extending their length, increasing the diversity of characters, changing them more frequently and making them more 'random' (rather

than based on words that might appear in a dictionary). Physical one-time keys can also be good for authentication. However, if things are made too awkward for legitimate users, they will find ways of circumventing the security system, actually reducing security. For instance, one-time key devices are likely to be left out on desks (potentially unguarded) if they are required many times each day.

This range of factors needs to be addressed in an appropriate manner, within the corporate security policy of the organisation.

5. Management issues in secure networks

This section concentrates on two key aspects of network management — security and fault management. In this context no unauthorised access or changes may be made to devices in the network, and the mechanisms that control this should themselves be secure. Unauthorised management access to a network device could allow unlimited access to the operation and contents of devices (e.g. modification of routing tables) could allow traffic to be diverted along unintended paths for further attack, or could lock out legitimate management access. Similarly, unauthorised access to service management systems should be prevented. For example, the replay of management messages could be used for nefarious purposes, such as shutting down an interface to force up a back-up link that is known to have a tap, or just to inconvenience the operator of the network.

The management system design must therefore take into account issues such as access control, replay prevention, certification, etc. Similarly, if there is an attack on the network, the network management centre should be made aware, and there should be established response procedures for such events.

The management of a network is typically carried out by some form of overlay network, generally an IP network. Management traffic is often kept separate from the customer traffic, either by carrying the information on separate connections, or with a different network numbering scheme. This often makes good sense since, in the event of a network outage or instability, the network management centre do not want the management messages caught up in the same network problem. Physical separation is preferable from a security viewpoint.

5.1 Network management protocols

There are currently two standards for network management — SNMP and CMIP. SNMP, the simple network management protocol, arose from a direct need within the Internet community for some form of uncomplicated network management system that could be implemented quickly with a minimal standardisation process. In contrast, CMIP, the common management

information protocol, is an OSI standard that is typically difficult to use and implement. As a result, SNMP has become the *de facto* standard for network management. However, SNMP has several key weaknesses that make it unsuitable for managing secure networks:

- access control is either read-only or wide-open,
- all information is passed in the clear,
- there is no form of message certification,
- there is no form of user identity verification,
- the protocol is open to replay attacks.

The level of access control available within SNMPv1 is very limited — access is only provided for either read-only or full read-write access. In order to implement the two levels of access, any device must have two ‘community strings’ defined — one for read-only access and the other allowing read-write access. This is a particular weakness of SNMPv1, as the community strings are passed across the network as plain text.

In either case, all of the management information may be accessed by the management system, and, with full read-write access, any information or function within the device may be modified. Therefore, a packet sniffer may be used to read the management passwords and therefore give open access to any device that uses the same password.

All SNMPv1 management messages are passed in plain text form. This is a serious limitation for any network management functions that may rely on privacy; for instance the configuration management of a device may be carried out by transferring a text-based configuration file between the device and the management station. Typically, this file contains information that can be used to deduce network topologies, network addresses, etc, which could all be used to direct further attacks.

Since messages are not authenticated, management information could be modified in transit, for instance to change an entry in a routing table or to shut down an interface. Again, such attacks can be used to maliciously redirect the flow of traffic within a network.

Because there is no means of authenticating the identity of the device that transmitted a message, the protocol is open to masquerade attacks, e.g. where a rogue management station is inserted into the network. It is, however, possible to limit the network addresses which may manage devices on the network.

Finally, SNMPv1 packets do not have a sequence number, and are therefore open to replay attacks. A simple example of a denial-of-service attack, based on replay, is

where a node is told to shut down an interface by playing back an old management message.

These issues, and several others regarding data transfer rates, etc, were drivers in the development of SNMPv2. This was intended to address the security problems, as well as many others including the transfer rate of management information. However, unlike the protocol that it was intended to replace, the standardisation process for version 2 resulted in a protocol that was difficult to implement and computationally intensive in use. This has resulted in much of the enhanced security being dropped from SNMPv2. Consequently, several other versions of SNMP have arisen, notably SNMPc (community-based, and no security improvements) and SNMPv2*, which has a lighter set of security functions to version 2. Because of the difficulty in implementing version 2 management systems, further effort on this version has been abandoned, and the next version, SNMPv3, is now on the standards track [19].

Enhanced security is provided by SNMPv3 as follows:

- access control is defined on a per-user/as-required basis,
- community strings are protected,
- message integrity is maintained,
- user identities may be authenticated,
- encryption is available if required,
- packets are time-stamped to limit replay.

In contrast to SNMPv1, access to the management information is defined for each user, and access to different management variables can be separately allowed or denied. This function therefore requires some similar form of access control to that provided by TACACS+, where there is a database of information for each device and user in the network. This database must be synchronised across all management stations, and must itself be secure from tampering.

The MD5 hashing algorithm may be used to authenticate users and to ensure message integrity. However, the authors of the protocol have borne in mind that MD5 may eventually be adjudged insecure, and there is a protocol descriptor that will allow the extension of the protocol to include other hashing algorithms.

Each SNMPv3 packet has a transmission time and lifetime. If the packet arrives after the time given by transmission time + lifetime, it may be ignored. It must be remembered that it is common within computer networks to have some amount of delay variation and packet reordering. It is therefore not possible, using a connectionless protocol, to prevent packet replay, while still allowing for permitted

behaviour. However, specifying the lifetime for a management message effectively limits the period during which replays are effective. The protocol purposefully does not use an external time synchronisation protocol for its timing decisions since an attack could be mounted by spoofing messages from the synchronisation node.

5.2 The network management system

The issues of physical security have already been raised in section 4.4. One of the most vulnerable areas of attack in a network is the management system. Typically, the management stations are Unix workstations, which run an open operating system that may be attacked via various routes, e.g. unauthorised TFTP access or e-mail hacking. Every effort should therefore be made to make network management stations for secure networks resilient to such attacks, by securing the access available from the network, and by providing a secure environment with controlled access. Mechanisms for this have been described in section 4.3.

If a network becomes too large for one management system to comfortably handle on its own, or for resilience purposes, several network management stations may be present on a network. Topology and other sensitive information will be passed between the management stations as part of the normal operation. This dialogue is very rich in information that an attacker could use to penetrate a network. Network management stations should therefore use a secure transfer mechanism to prevent such attacks.

5.3 Managing secure devices

The management of devices which provide traffic encryption facilities within a network raises several interesting issues:

- bringing devices on-line,
- managing key exchanges,
- action on tampering,
- securing the management dialogue,
- secure and effective recovery procedures.

Activating a new device is not a trivial operation, particularly since it must be ensured that the device added to the network is the intended device, and not a rogue. Although it would be possible for a management station and a new network device to set up a secure dialogue using a public-key encryption technique, this does not validate the remote node. It is essential to properly or strongly authenticate the remote device, therefore it is best to use a technique that reports a number back to the management

system via a secure channel, e.g. the installation engineer reading some form of secure electronic serial number to the network manager over a GSM (i.e. secure) telephone link.

The traffic encryption key exchange policy must be carefully set throughout the network. Keys should be changed frequently to limit the amount of information compromised if a key is broken. One way of ensuring this is to change a key long before it can be broken. For example changing a 56-bit DES key every 24 hours is probably quite safe for the next year or two, while a 40-bit key should be changed every hour. Also, in the event of a compromise, real or suspected, the network manager should be able to force some or all of the keys within a network to re-negotiate.

If a network encryption device is impaired, suitable action must be taken. This should include notifying the management station, and taking the unit off-line. Bringing the unit back on-line should then require manual interventions, either through a unit-swap, or via a re-commissioning process.

The dialogue between the management system and the managed device must not be open to hijacking by another party. For example, there are deficiencies in TCP/IP that can allow traffic to be inserted by an attacker. The management dialogue must not be open to such an attack.

The management system must be resilient to failure; if there is only one management system, the network has a single point of failure and is at risk if this fails. Conversely, the use of multiple management systems can raise difficulties with database synchronisation issues. In the event of a failure, there must be adequate back-up information to bring a new system back on line correctly.

As described above, the secure management of network devices is not provided for within the first version of SNMP. As a result, all management systems for network encryption devices tend to use their own proprietary 'secure SNMP' protocols. These protocols allow for verification and privacy facilities within the dialogues.

5.4 The current position

Since SNMPv3 is not fully standardised yet, and there is no clear *de facto* standard among the other versions, it is very likely that either the management system or the managed nodes within a network will preclude the use of anything other than SNMP version 1. If this is the case, the following three restrictions apply.

- SNMP should only be used for gathering information and traps, not for control purposes. Since SNMPv1 messages can be forged and snooped, the use of SNMP to configure and set attributes within devices should be discouraged. It is likely, however, that the best means of informing the management system of important network events (e.g. link failures) is still via the use of SNMP traps, despite the fact that they may be forged. Increased use of polling could be used to provide an alternative, or to supplement the information gained by traps.
- Community strings should be varied throughout the network. To limit unauthorised access to multiple nodes within a network, different community strings should be used for as many different devices as possible. However, this then brings up the issues of configuration control and that human operators will be running the management system. It may be impracticable to have a different community string for every device on a network.
- Remote configuration using Telnet should be carried out using an appropriate access control mechanism, e.g. TACACS+/RADIUS, etc.

Since the remote configuration of a device using SNMP is not recommended, then other access methods such as TACACS+ should be used instead. This will then limit what commands may be carried out by which operators, and from which network addresses. However, it relies on the managed node having a Telnet interface.

6. BT security services

Concert and BT are about to launch a number of security services. These are described below.

6.1 Concert's IP SubNet Encryption Service

Concert's IP SubNet Encryption Service offers data encryption over Concert's Frame Relay Service thereby ensuring privacy between any two customer premises' end-points on the Concert Frame Relay Network. The service provides the following security aspects:

- privacy using 56-bit DES,
- certification and authentication,
- automatic key exchange,
- access control (LAN-based encryption policy),
- audit trail and scalable security management.

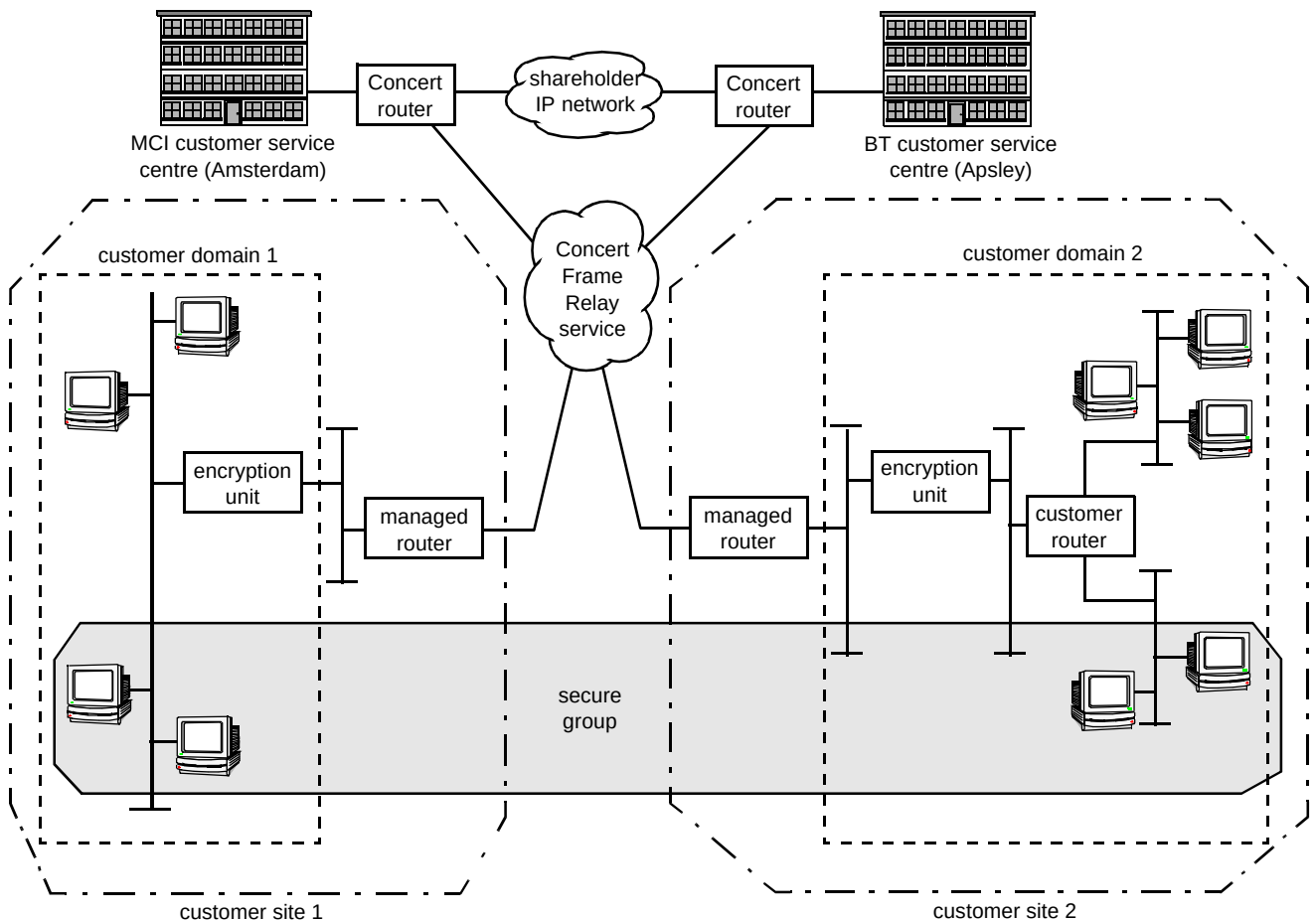


Fig 12 Concert's IP SubNet encryption.

Figure 12 shows the basic elements of the service. The service uses intelligent hardware encryption units and a software-based encryption management system. The encryption unit is the hardware at the customer's site that provides data security over IP or Novell IPX (or both) networks; despite the name of the service, it supports both IP and IPX packets. Residing on the LAN (Ethernet) side of an access router, the hardware is managed by means of a software application that runs on a workstation. The software application operates a proprietary, secure version of SNMPv1. Management, both encryption and general network, is provided by one of the two network management sites in Amsterdam, Holland or Apsley, England.

The Shareholder Network is a management network owned by Concert and operated by BT and MCI. It is used to ensure that BT and MCI can get appropriate visibility of customer networks that span both operators' jurisdictions.

prerequisite of the encryption service. Routers that are on the clear side of the encryption unit are deemed to be customer routers and these are not managed as part of the service.

The encryption units are store-and-forward devices which make access control decisions based on internal connection tables that are constructed in accordance with the 'security policy' adopted by the system administrator and defined at the security management workstation. Packets arriving at an encryption unit are encrypted, decrypted, rejected (deleted) or bypassed depending on the security policy.

Each encryption unit can secure connections with up to 500 other encryption units and can form up to 96 closed user groups. The establishment of closed user groups (also called secure groups) is quite complex and is determined by the security parameters set for their component parts. In the context of the Concert offering, the component parts are as follows.

- LAN entity

For networks running IP protocols a LAN entity is a network device (e.g. a single host) or group of devices that share a common network address (e.g. IP subnet). For networks running Novell NetWare IPX protocols, a LAN entity is a group of network devices that share a common network number; under IPX, entities cannot be defined down to host level.

- Customer domain

A customer domain is defined as a collection of LAN entities that are protected by a single encryption unit; it includes the encryption unit itself. Multiple encryption units will define multiple domains. Data cannot enter a customer domain without passing through an encryption unit.

- Secure group

A secure group consists of a collection of LAN entities that reside in different domains. A secure group will have an assigned internal communications policy (or a set of security rules) that defines the connectivity relationships between the entities within the group. The security rules include access control (e.g. can entity A communicate with entity B?), group confidentiality (e.g. encrypt or by-pass), and how entities within domains can communicate with unprotected hosts or sites.

Traffic encryption keys are assigned on a per-connection basis (site-to-site) and are updated automatically as soon as the current key has expired, as defined by the key update interval. This can be set to any value in the range 3 to 65 535 minutes, the default being 1440 minutes (24 hours). Traffic-key updates between encryption units are performed using the Diffie-Hellman key agreement protocol described earlier (see section 2.5). Apart from setting the key update interval, the management system plays no part in the generation and distribution of the traffic keys, i.e. it is not a key server.

The service uses security certificates to provide authentication mechanisms for the component parts of the system. These include manufacturer's certificates for both the management system and the encryption units. Manufacturer's certificates bind the individual encryption units to the management system. This enables the management system to create the necessary identification and control capability to allow for secure and authorised cryptographic communications within its authority domain. As the name implies, the manufacturer's certificate is generated by the manufacturer and thus the manufacturer is the certification authority (CA) for this security system. This CA responsibility is, in effect, delegated down to the encryption management workstation.

In addition to acting as a delegated certification authority, the management system maintains customer configuration information on all encryption devices and logs all events related to those devices.

The security management workstation uses standard password protection mechanisms and is housed in a secure environment. Further security procedures have been implemented by Concert to secure the physical environment and system access minimising any compromise from the management facility.

At the time of writing, the service is available for global launch, but the final launch dates depend on the local arrangements in each country where the service is to be launched.

6.2 BT-managed SMDS encryption service

This service offering has been developed in direct response to the customer demand for a high-speed managed data encryption service on advanced data networks based upon BT's switched multi-megabit data service (SMDS). It is initially targeted at large-to-medium financial institutions, particularly banks, but can also be offered to non-financial enterprises. In addition to the security features provided on SMDS [20], the encryption service provides:

- privacy using multiple encryption algorithms (40-bit and 56-bit keys),
- peer authentication,
- message authentication,
- access control (site-based encryption policy),
- audit trail and scalable security management,
- customer network management.

The elements of the service are shown in Fig 13. In line with the Concert offering, this service uses intelligent hardware encryption units and a software-based, encryption-management system. The SMDS encryption unit is the hardware at the customer's site that provides data security over SMDS networks.

The units are managed via a workstation-based network security management application. The software application again operates a proprietary, secure version of SNMPv1. (The management workstation may be located anywhere provided that it has IP paths to all managed encryptors.) In practice, both encryption and general network management are provided from Apsley, with a back-up system in London. The architecture of the system allows customers to have their own customer network management (CNM)

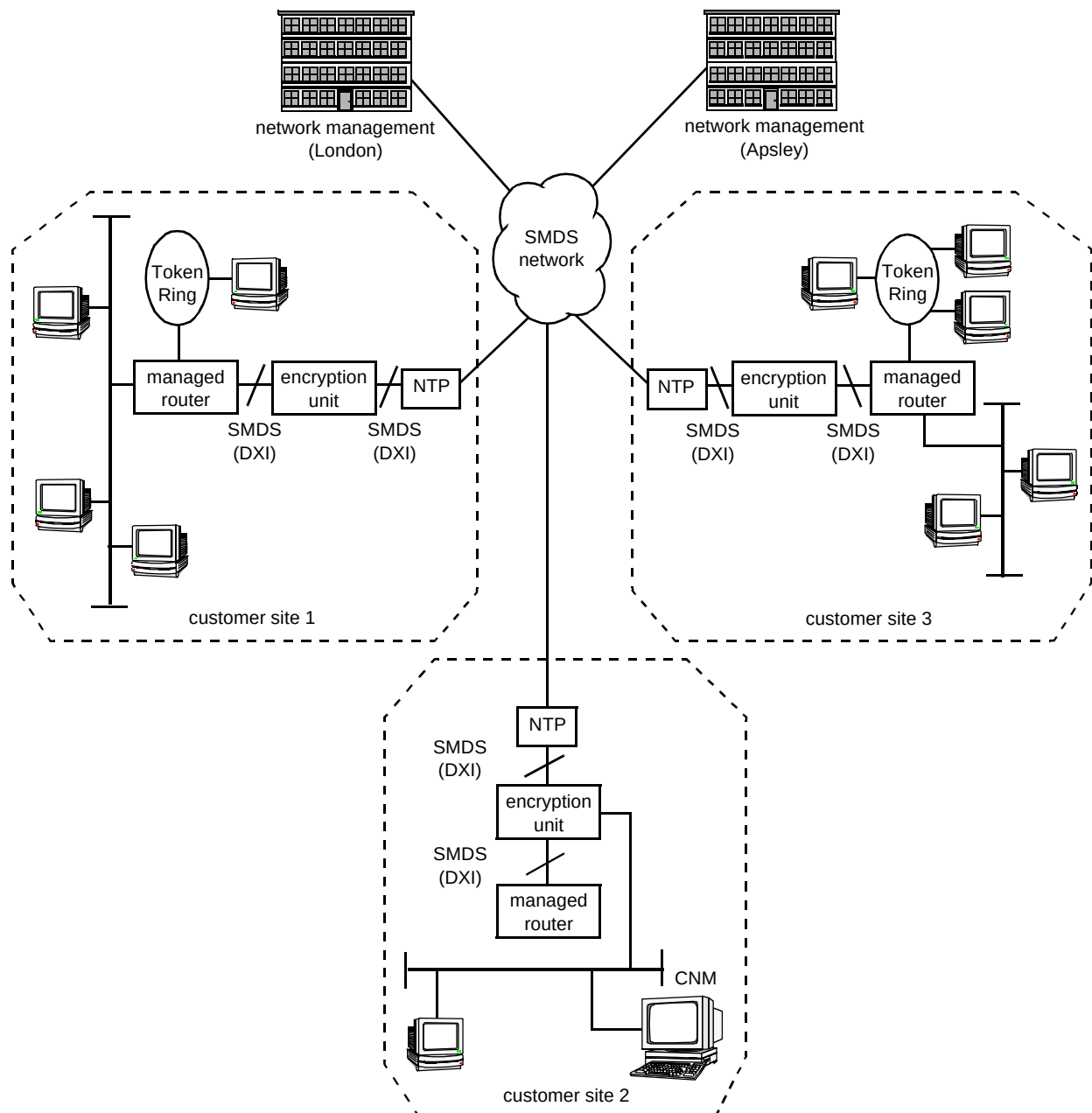


Fig 13 Managed SMDS encryptions.

centres, enabling them to manage their own security network should this be required as part of their existing security management policy. The CNM uses the same application as used by the network management centres. Unlike the network management centres, however, the CNM is restricted solely to the specific customer's domain.

SMDS encryption system

The SMDS encryption unit resides between the access router and the SMDS access port (e.g. network terminating

equipment (NTE) at the customer's premises) and includes an Ethernet-based management port.

A normal interface between the router and the SMDS network terminating point (NTP) is called the SMDS data exchange interface (DXI). The SMDS encryption units therefore have DXI interfaces, so that they can be located between the access router and the NTP.

Thus, this encryption system is effectively a link-layer encryption system. It does, however, have the flexibility to selectively encrypt data on the basis of the source and

destination network (E.164) addresses. As the encryption takes place at the link-layer, it supports all the higher-layer protocols that the router supports. Thus all higher-layer protocols can be transported without the need for tunnelling or encapsulation in IP between access routers.

The security features offered by the service are possible owing to the structure of the secure SMDS frame format used. A simplified diagram of this is shown in Fig 14.

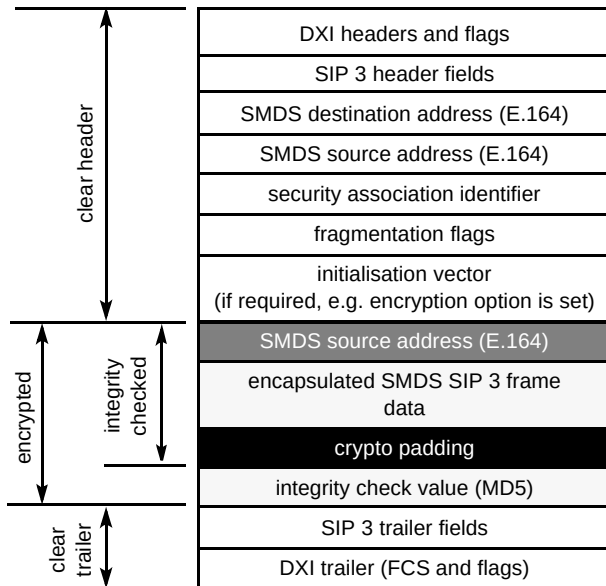


Fig 14 SMDS secure frame structure (abbreviated).

A number of fields in the secure frame structure are passed in the clear and used by the communicating encryption units to provide the security services. Because the security services can only be provided by the addition of security overhead fields (e.g. IV, crypto-padding) a maximum-sized frame can only be supported by the encryption unit if it is fragmented on encryption and reassembled on decryption. Hence the use of fragmentation fields.

Following the clear header, the next field contains the SMDS source address. This is used to support authentication of the origin. If, at the destination, the decrypted source address does not match the source address in the header, the packet is rejected. The next field contains the encapsulated SMDS SIP3 frame which is followed by padding and finally the ICV, computed using MD5. This ICV provides the message authentication service.

By default, all of the security services offered by the security system are enabled. However, encryption can be disabled, in which case the IV field is not present.

In common with the Concert service, the SMDS encryption units are store-and-forward devices which make access control decisions based on internal connection tables. These connection or access control tables are constructed in accordance with the 'security policy' adopted by the system administrator and defined at the security management workstation. Packets arriving at an encryption unit are encrypted, decrypted, rejected (deleted) or bypassed depending on the security policy. Each SMDS encryption unit can secure connections with up to 1024 other encryption units, though the size of an SMDS closed user group (CUG) imposes a further limit.

The establishment of SMDS security groups is quite simple and based on access control as defined on a site-by-site basis; it is not possible to define subnetworks behind a site router (to form secure groups) unless the subnetwork can be defined by a single E.164 address.

The network security system has a number of encryption keys including those keys used between:

- peer encryption units,
- peer management workstations,
- encryption units and management workstations

The lifetime of each of these keys can be set at the management workstation down to about one hour. The default lifetime is one week. Key updates are carried out using an RSA-based public-key envelope; the symmetric DES key is encrypted as part of a key negotiation that is protected using RSA public-key techniques.

The encryption units have three user-configurable security levels that define how they will operate if a secure connection¹ cannot be established; the default is always to establish a cipher-based connection if possible, unless the system administrator specifically selects bypass or reject for certain connections.

The SMDS security system uses a number of security certificates to provide authentication mechanisms for the component parts of the network. These certificates are generated by the network management system; thus, the certification authority is the network management system itself.

¹ In this context, a 'secure' connection is a connection that is established via two encryption units; it is not necessarily encrypted.

Service launch

The service is only available through BT Syncordia Solutions as a constituent part of a managed high-speed network. It is available within the UK and also globally on any high-speed SMDS network designed and managed by BT. The Release 1 product will enable encryption over the BT SMDS service at speeds of up to 10 Mbit/s. Subsequent releases are planned to increase this to 25 Mbit/s (SMDS Access Class 4). At the time of writing, the service has a planned launch date of early 1998.

6.3 Security-related services

In response to the major growth in corporate intranets and the commercial use of the Internet, BT has developed a number of intranet and Internet products and services. Some of these products and services contain security elements. One such service is 'BT Intranet Complete'. This is a fully managed intranet service aimed at companies who do not wish to manage their own corporate intranet. One feature of this service is 'Secure Internet Access' which establishes a secure connection between the corporate intranet and the Internet, enabling controlled access to the Internet while protecting sensitive company information from unauthorised intrusion.

Secure Internet Access is provided by means of a managed firewall which is configured to meet the security needs of the corporate customer. It also allows Internet services (e.g. SMTP mail, NNTP Usenet, New DNS Query and Secondary DNS facilities) to be granted on a user-by-user basis. BT Intranet Complete also includes a suite of applications such as on-line directories and closed user groups. Application security is provided by a distributed password authentication service which is integrated with the administration and directory services to enable the establishment and control of special user groups and discussion forums.

BTnet Secure is an enhancement to BT's existing BT *net* Internet service. As with the Secure Internet Access feature of BT Intranet Complete, this is also based on a fully managed firewall. In contrast to the BT Intranet Complete service, BTnet Secure is designed solely to protect companies' networks from intruders, not to establish VPNs.

BTHealthNet [21] incorporates security features provided by one-time passwords (generated by users' smart cards), and for ISDN communications uses CLI and CHAP. CampusWorld [22] uses an encrypted log-in system to protect its more sensitive services, and BT strong encryption technology for PIN encryption and secure file transfer. BTWebWorld [23] (a Web-hosting service) provides SSL host-layer encryption. It also makes use of

digital certificates, using VeriSign [24] as the Certification Authority (CA) or trusted third party.

7. Security futures (ATM)

There seems to be little doubt that the high-speed network platforms of the future will be ATM based. For this reason this section summarises the ATM Forum's recent proposals on ATM security, and assesses the impact that such proposals are likely to have on BT's future ATM platforms. The time-frame considered here is 1—5 years.

7.1 ATM Forum proposals

The ATM Forum considered security somewhat as an afterthought, though the Phase 1 Security Specification (SSP1) [25] should be ratified by the end of 1997. This section summarises the proposals in this Phase 1 specification.

SSP1 is concerned with security in two 'planes' — the user plane and the control plane. The user plane provides transfer of data across virtual circuits and paths, while the control plane deals with connection establishment, release and UNI, NNI and ICI signalling. SSP1 does not cover security in the management plane, which performs management and co-ordination functions related to both user and control plane — such as PNNI [26].

Four security services are considered by the SSP1 specification:

- access control,
- authentication,
- privacy or confidentiality,
- data integrity.

The scope of SSP1 is illustrated in Table 1.

Table 1 The scope of Phase 1 Security Specification; the shaded areas are covered in the specification.

	User plane	Control plane	Management plane
Access control			
Authentication			
Confidentiality			
Data integrity			

7.2 Access control

ATM access control is governed by the policy of only allowing specific ATM addresses, on specific switch ports, to establish connections to specified destination ATM addresses on specified ports on specified destination switches.

Access control is a powerful technique — it will stop the casual invalid user connecting to the network. Connections will be blocked unless the ‘hacker’ spoofs a legitimate ATM address (NSAP or E.164) for the relevant switch port. It is not enough to merely spoof an address — it has to be done from a valid access point. There are a number of ways to implement access control, including address screening and the establishment of CUGs. VPNs could also be implemented using network intelligence.

Address screening

Address screening can enable the validity of the user-provided calling party number to be checked (either by the network or by the user), and the call to be established or rejected depending on that number. The simplest way of doing this is for the network to provide calling line identity (CLI), and for customer policy to reject or accept the call accordingly. This is analogous to the ‘1471’ service on the PSTN. Address screening is important since, in the absence of a CUG service (for example non-corporate customers), it may be the only form of access control for switched services. Address-screening is not specified in the ATM Forum UNI 3.0 and 3.1 documents, but proprietary mechanisms can provide this function by the configuration of access-lists on relevant switch ports — only permitting calls between specified addresses; but this may prove difficult to scale. Because address-screening by the network rejects invalid calls at the point of ingress to the network it is better at preventing denial of service attacks.

Closed user group

Closed user group is a signalling supplementary service that can be used to implement virtual private networks (VPNs) across an ATM core. It provides call security for incoming and outgoing calls, and makes it possible for users to form groups with restricted access. Membership of a CUG is configured by the network after mutual agreement between the network and the user. Members in a CUG can receive calls from outside a CUG and make calls to destinations outside their CUG if so specified. Membership in a CUG can be preferential, i.e. the CUG is supported fully on the network side and the user does not have to signal it. CUG is standardised by the ITU for both UNI and NNI, but standardisation work in the ATM Forum is ongoing. The ATM Forum CUG will require both UNI 4.0

signalling, and the use of an additional information element in the call set-up message.

It should be noted that there is a proposal that only the network side of CUG should be supported, in which case no CUG signalling would be required by the CPE. This would be easier to administer than address screening tables, though less flexible than CUG signalled over the UNI.

ILMI allows a switch to distribute ATM prefixes, and it is typically used in LANE or to facilitate route aggregation, to prevent the size of ATM routing tables growing too large. (It should be remembered that the size of routing tables is the main problem on today’s Internet). However, ILMI can be used to simplify access-control configuration and to improve security. Forcing users to take a prefix from the switch and only accepting calls with that prefix can help to prevent non-valid accesses; for example, spoofing the address of a member of another CUG.

CUGs will be generally simpler to configure than network-based address-screening, and should be used for corporate networks. Residential broadband customers will not be part of a CUG, and address-screening will be an appropriate security mechanism.

Access control in BT’s ATM platforms can be provided through extensive use of CUGs and ATM address screening. A strong access control policy may be defined as follows:

- ports on a CUG should be configured to only accept call set-ups from allowed addresses, such as other members in that CUG or management stations,
- customers should be encouraged to use ILMI on their private networks to give route aggregation and simplify CUG and address screening on a BT ATM network.

Together these mechanisms will prevent unwanted calls being established between customer devices, providing ATM-layer security. Additional methods for higher layers (e.g. IP) may still be required. It is worth noting that a future network intelligence platform may also provide an option.

7.3 Authentication

Authentication goes a step further than access control, by ensuring that the identities of calling and called parties are genuine. Node verification occurs at the beginning of the connection, and can be either unilateral (one party verifies the other) or mutual (both parties verify each other).

Two methods are specified for negotiating security services — signalling-based and in-band. Signalling-based

uses a dedicated signalling channel to carry security data, and a connection will only be established when either or both relevant parties have been authenticated; in this case, authentication is performed in the control plane. Conversely, in-band authentication is performed out of the control plane, meaning that a connection is established, and authentication then takes place and must be completed before data can flow. These variants give the option of performing the authentication process on the core switches or in a separate authentication server.

In-band is the simpler option, and the ATM Forum have proposed in-band message exchange as a fall-back mechanism for signalling-based message exchange. Authentication messages are carried between end-points by SMEP (security message exchange protocol), using signature algorithms such as RSA or DSA to perform authentication.

Control plane authentication is the ATM security service which binds an ATM signalling message to its source. Control plane authentication differs from user plane authentication in that a signalling message has both end-to-end and hop-by-hop significance. Control plane authentication could be used, for example, to provide audit information for billing or to authenticate one switch to another in the signalling route.

SSP1 also covers control plane authentication of UNI signalling messages. However, each switch through which the messages pass can modify the contents, making it difficult to specify information which remains unchanged between the creator and verifier of a signature. Unlike user plane data, there is no opportunity for a two- or three-way exchange protocol for control plane authentication, since authentication must be verifiable as the signalling message traverses the network. Additionally, the creator of all intermediate nodes which may wish to verify the message; PNNI determines the route through the network, obstructing the use of signature protocols, which require a destination identity.

Because of these problems, SSP1 defines only hop-by-hop authentication of signalling messages between adjacent nodes, with pre-placed keys and algorithms. A single key authenticates signals associated with many different connections, to minimise the additional processing. This authentication provides some protection against modification of signalling in transit between adjacent switches.

7.4 Confidentiality

Confidentiality as provided by encryption will typically be required on a per-VC basis; for example, some connections may need encryption, while others might not. (The signalling PVC is an obvious example of a VC which would not normally be encrypted.) Encryption is applied to the sequence of data cells (i.e. not headers) and can be applied on a per-VC basis to the cell payloads (i.e. this is distinct from link encryption).

The simplest way of achieving encryption is via the use of external CPE encryption units on a customer's site, to encrypt the payload contents of the VC. The encrypted cells would then be carried transparently over the network, to be decrypted by a similar box at the remote customer site. This box could be customer-owned or provided by BT as value added to a managed service. Early versions of such encryptors are available (but only deal with PVCs); their suitability for a commercial service offering needs to be assessed.

7.5 Data integrity

The proposed data integrity service is achieved by appending a signed message authentication code (MAC) to each data unit, e.g. at the adaptation layer. At the destination, if the signature is not correct the AAL-SDU is discarded, a counter is incremented and an appropriate alarm generated. To protect against replays, a sequence number is used. The two protection mechanisms for AAL level data integrity are shown in Fig 16.

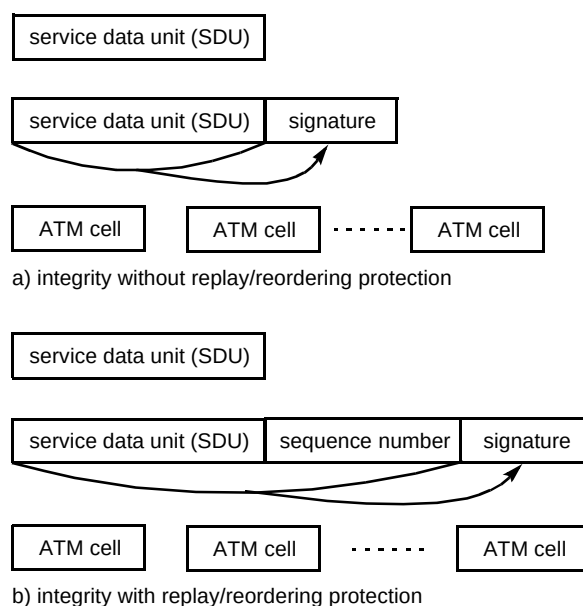


Fig 16 Mechanism proposed for AAL-level data integrity.

Data integrity, like data confidentiality, needs to be performed by CPE at the customer site, meaning that it does not impact on the core of the ATM network. This could form part of a managed network service offering.

7.6 Data networks

Currently firewalls, most commonly in the form of screening by router access lists, are used to secure access at layer 3. For example, on an SMDS-attached router, traffic from the WAN SMDS serial interface is disassembled to the IP layer, and only forwarded through the router to remote interfaces if it meets the rules of the firewall.

Such a mechanism could be used for layer 3 traffic carried over ATM (essentially a router with multiple ATM interfaces), but this would increase delays. While this may be adequate for a data-only scenario, it would not be suitable for direct ATM connections such as ATM videoconferences. Essentially, in the future, many customers might wish to establish peer-to-peer video or phone calls from their desktop machines, but preclude IP sessions to the same destination computer.

An additional ATM security function will be required, capable of applying IP-firewall functions on some VCs, while letting others pass transparently. Initial support for PPP-over-ATM is now available, meaning that well-established techniques such as CHAP can be used to prevent layer 3 access over ATM under certain conditions.

ATM security standards are still evolving, and though few products have yet appeared in the market-place, more will inevitably be seen in the near future. It seems likely that the data encryption function will reside at the customer's premises in a specialised CPE product, and not in the network. Notwithstanding this, the expertise derived from the provision of managed encryption services (see sections 6.1 and 6.2) should position BT favourably as a supplier in the future.

8. Conclusions

This paper has examined the construction of secure data networks from the perspective of the components used and where they are located in the network.

The key function of data encryption may be located in any (or all) of the essential layers — application, network and link. There are advantages and disadvantages to any particular choice, to be carefully considered within the context of the network design.

A number of access control techniques have been described, of which TACACS+ and the one-time password

are strong mechanisms currently available. Despite the relative merits of the stronger access control mechanisms listed above, the weakest link in a security system is usually human failure, or culpability on the part of the user or system manager.

Management of security devices within a secure network is very important, particularly as part of a managed service. The first secure network management protocol (SNMPv2) proved to be unwieldy and difficult to implement, with the net result that it was never fully completed and has now been abandoned. Until the appropriate open management standards (e.g. SNMPv3) are completely developed, it is reasonable to assume that vendors will retain their proprietary solutions.

The use of SNMPv1 in a secure environment should be limited to the polling of devices and the monitoring of traps. Remote configuration should be carried out by Telnet sessions, with controlled access via TACACS+/RADIUS, etc.

The customer demand for security service provision, in particular encryption services, is increasing as customers migrate to the more cost-effective public switched networks to carry data. For some customers (e.g. banks and financial institutions), encryption is seen as a prerequisite of the service and not merely an enhancement to it. In recognition of this key market enabler, BT and Concert have developed solutions for the newer network offerings of SMDS and Frame Relay respectively.

These products address similar market requirements in similar ways, but are based on slightly different implementations. BT's SMDS encryption product encrypts at the link layer protocol on a site-by-site basis. Concert's IP SubNet encryption service encrypts at the IP (or IPX) network layer.

Because the advantages and disadvantages depend so much on the particular customer environment, it is not possible to make specific or absolute recommendations with regard to either the performance or the implementation (e.g. link versus network layer) of these products.

The example of the ATM Forum shows that security standards have been recognised, albeit as an afterthought, as an essential part of the protocols required in future networks.

Acknowledgements

The authors would like to thank Dave Newson for his valued contribution to the section on security futures, and Martin Moore for useful discussions and comments.

References

- 1 Phoenix S J D, 'Cryptography, trusted third parties and escrow', BT Technol J, 15, No 2, pp45—62 (April 1997).
- 2 Hubbard S D, Sager J C, 'Firewalling the net', BT Technol J, 15, No 2, pp94—106 (April 1997).
- 3 Schneier B: 'Applied cryptography', John Wiley & Sons (1996).
- 4 Caronni G and Robshaw M: 'How exhausting is exhaustive search', CryptoBytes, RSA Laboratories, 2, No 3 (Winter 1997).
- 5 'Government encryption standard DES takes a fall', RSA Laboratories (June 1997), <http://www.rsa.com/des/>
- 6 Rivest R L, Shamir A and Adleman L: 'A method for obtaining digital signatures and public-key cryptosystems', Communications of the ACM, 21, No 2 (February 1978).
- 7 Diffie W and Hellman M E: 'New directions in cryptography', IEEE Trans on Information Theory, IT-22 (Nov 1976).
- 8 'Licensing of trusted third parties for the provision of encryption services', DTI Public Consultation Paper (March 1997), <http://dtiinfo1.dti.gov.uk/pubs/>
- 9 CCITT Recommendation X.509: 'The directory — authentication framework', (1988).
- 10 Whalley G M, Hitchen P, Linsell K, Smith A C A and Mylotte P: 'Advanced internetwork design — today and in the future', BT Technol J, 16, No 1, pp 25—38 (January 1998).
- 11 Moy J: 'OSPF version 2', RFC 1583 (March 1994).
- 12 Moy J: 'OSPF version 2', RFC 2178 (July 1997).
- 13 Rivest R: 'The MD5 message-digest algorithm', RFC 1321 (April 1992).
- 14 Murphy S et al: 'OSPF with digital signatures', RFC 2154 (June 1997).
- 15 Finseth C: 'An access control protocol, sometimes called TACACS', RFC 1492 (July 1993).
- 16 Rigney C et al: 'Remote authentication dial-in user service (RADIUS)', RFC 2138 (April 1997).
- 17 Rigney C: 'RADIUS accounting', RFC 2139 (April 1997).
- 18 Everett C, Blakey K, Morgan L: 'The role of ISDN in data networking', BT Technol J, 16, No 1, pp 39—51 (January 1998).
- 19 IETF Working-group for SNMPv3 Charter, <http://www.ietf.org/html.charters/snmpv3-charter.html>
- 20 Lewis D J et al: 'Four years of the Switched Multi-megabit Data Service', BT Technol J, 16, No 1, pp 16—24 (January 1998)
- 21 Frost A J: 'BTHealthNet — an early intranet case study', BT Technol J, 15, No 2, pp 114—125 (April 1997).
- 22 Leveridge P C: 'CampusWorld', BT Technol J, 15, No 2, pp 126—131 (April 1997).
- 23 Cameron I and Patrick D: 'BTWebWorld', BT Technol J, 15, No 2, pp138—144 (April 1997).
- 24 <http://www.verisign.com>
- 25 'Phase 1 ATM security specification', Security Working Group, ATM Forum (July 1997).
- 26 Clarke P L, Cooper N J P and Sutherland D J: 'ATM — the next generation', BT Technol J, 16, No 1, pp 106—113 (January 1998).



Steve Forrester joined BT in 1985 after receiving a Masters degree in Telecommunications Systems from the University of Essex. His first three years were spent designing low-cost optical transmission systems for video and high-speed data applications. This was followed by two years evaluating the performance of physical layer components for local area networks design rules. He joined the Broadband and Data Networks unit in 1991 to complete the design of an experimental ATM switch and has since been involved in the development of broadband applications for use with BT's

core data services. For the last four years he has been working on the development of encryption products for data security services for both BT and Concert. He is a Chartered Engineer and a Member of the IEE and the IEEE.



Mike Palmer has been in the Broadband and Data Networks unit for 12 months, having worked in Systems Integration since 1989, when he joined BT. Prior to that he worked as a technical training officer for FerrantiGTE in private voice and data networks. After graduating from Reading University in 1969 with an honours degree in Physics, he spent 12 years as a teacher. Currently, he is a member of the internetworking team, involved in a wide range of data communications technologies, with particular interest in network design rationalisation.



managed services. He is an Associate Member of the IEE.

Dave McGlaughlin joined BT in 1988 as a sponsored student. In 1989, he graduated from UMIST with a BSc in Electronics. Since then he has worked on expert systems for fault diagnosis, implemented a real-time non-intrusive error monitoring system for use at BT earth stations, and created a simulation library for TCP traffic on Frame Relay links over satellite links. He completed the BT MSc in 1995 and is now working in the internetworking team in the Broadband and Data Networks unit where he is involved in many areas regarding data networks, particularly network management and



Matthew Robinson joined BT as a sponsored student in 1992 and undertook various projects including work for the Broadband and Data Networks unit on advanced routing protocols.

In 1996 he graduated with an MEng in EIST from Cambridge and then joined the Broadband and Data Networks unit full time.

He is involved in a wide range of activities relating to data networks, and especially routers and network operating systems. He is currently an Associate Member of the IEE.